

REST API Reference

Conventions

- Local server: `http://localhost:5000`
- API base: `http://localhost:5000/api`
- Request/response media type: JSON
- Protected routes require `Authorization: Bearer <JWT>`.
- Most successes use `{ "success": true, "data": ... }`.
- Errors generally use `{ "success": false, "message": "..." }`.
- Invalid IDs/validation errors often surface as 500 in the current implementation; clients should not rely on that behavior.

Health

Method	Path	Access	Behavior
GET	<code>/health</code>	Public	Confirms Express is running; it does not test MongoDB readiness

Authentication and profile

Method	Path	Access	Body
POST	<code>/api/auth/register</code>	Public	<code>name</code> , <code>email</code> , <code>password</code> , optional <code>phone</code> , <code>address</code> , <code>role</code>
POST	<code>/api/auth/login</code>	Public	<code>email</code> , <code>password</code>
GET	<code>/api/auth/profile</code>	Authenticated	None
PUT	<code>/api/auth/profile</code>	Authenticated	Any of <code>name</code> , <code>email</code> , <code>phone</code> , <code>address</code> , <code>password</code>

Example login:

```
curl -X POST http://localhost:5000/api/auth/login \  
-H 'Content-Type: application/json' \  
-d '{"email":"user@example.com","password":"secret123"}'
```

Security warning: `register` currently honors the requested role. A secure implementation must ignore `role` and create public accounts as `USER`.

Templates

Method	Path	Access	Input/notes
GET	<code>/api/templates</code>	Public	Query: optional <code>search</code> , <code>location</code>

Method	Path	Access	Input/notes
			regex filters
POST	/api/temples	ADMIN	Required: name , location , darshanStartTime , darshanEndTime ; optional media , description , amenities
GET	/api/temples/:id	Public	Temple ObjectId
PUT	/api/temples/:id	ADMIN	Partial temple update
DELETE	/api/temples/:id	ADMIN	Deletes only the temple document; no cascade
POST	/api/temples/:id/reviews	Authenticated	rating , comment ; creates or updates caller's review
POST	/api/temples/:id/events	ADMIN	title , date , optional description
DELETE	/api/temples/:id/events/:eventId	ADMIN	Removes embedded event
POST	/api/temples/:id/maintenance	ADMIN	description
PUT	/api/temples/:id/maintenance/:maintenanceId	ADMIN	status

Example search:

```
curl 'http://localhost:5000/api/temples?search=kashi&location=varanasi'
```

Slots

Method	Path	Access	Input/notes
GET	/api/slots	Public	Query: optional templeId , date (YYYY-MM-DD)
POST	/api/slots	ORGANIZER/ADMIN	temple , date , startTime , endTime , availableSeats , optional price
GET	/api/slots/:id	Public	Returns populated temple name/location
PUT	/api/slots/:id	ORGANIZER/ADMIN	Partial date , times , availableSeats , price

Method	Path	Access	Input/notes
DELETE	/api/slots/:id	ORGANIZER/ADMIN	Deletes slot without checking existing bookings

Example create:

```
{
  "template": "<templateObjectId>",
  "date": "2026-07-20",
  "startTime": "08:00 AM",
  "endTime": "10:00 AM",
  "availableSeats": 50,
  "price": 150
}
```

Bookings

Method	Path	Access	Input/notes
GET	/api/bookings	ORGANIZER/ADMIN	Organizer may pass <code>templateId</code> ; without it all bookings are returned
POST	/api/bookings	Authenticated	<code>slotId, devotees[]</code> ; creates five-minute hold
GET	/api/bookings/my-bookings	Authenticated	Caller's bookings, newest first
POST	/api/bookings/:id/confirm-payment	Authenticated	No payment payload; marks pending booking as booked
PUT	/api/bookings/:id/cancel	Authenticated	Owner check applies only when caller role is USER

Booking hold request:

```
{
  "slotId": "<slotObjectId>",
  "devotees": [
    { "name": "Ananya Reddy", "age": 29, "gender": "Female" },
    { "name": "Rahul Kumar", "age": 31, "gender": "Male" }
  ]
}
```

Successful hold returns populated booking data plus `expiresAt` and `holdTimeSeconds: 300`. Confirmation does not contact a payment processor.

Donations

Method	Path	Access	Input/notes
GET	/api/donations	ORGANIZER/ADMIN	Optional templateId ; organizer is not automatically scoped
POST	/api/donations	Authenticated	templateId , amount , optional purpose , donorName , isAnonymous
GET	/api/donations/my-donations	Authenticated	Caller's donations

Example donation:

```
{
  "templateId": "<templateObjectId>",
  "amount": 500,
  "purpose": "Anna Danam (Food Distribution)",
  "donorName": "Ananya Reddy",
  "isAnonymous": false
}
```

Administration

Method	Path	Access	Input/notes
GET	/api/admin/analytics	ADMIN	Summary, popular temples, age demographics
GET	/api/admin/users	ADMIN	Optional role query
PUT	/api/admin/users/:id	ADMIN	Partial name/email/phone/address/role/password
DELETE	/api/admin/users/:id	ADMIN	Prevents current last admin deleting itself; other edge cases remain

Analytics revenue is a sum of recorded booked totals and recorded donations. Because payment is simulated, it is not settled financial revenue.

Status codes observed

Code	Meaning in current API
200	Successful read/update/delete/confirmation
201	Created registration, temple/slot/booking/donation/review/event/maintenance
400	Duplicate account, invalid booking state/capacity, selected business-rule failures
401	Missing/invalid JWT or invalid credentials
403	Role or ownership failure
404	Resource or route not found

Code	Meaning in current API
500	Unhandled controller/database/schema error
503	MongoDB is not connected for <code>/api</code> requests